Compliance and audit logging: set a secure baseline, then prove it holds

A **security baseline** is the set of controls every workspace must have. The **compliance security profile** hardens the compute that runs your code. **Audit logs** record who did what, so you can show an auditor that the controls work.

> LEARNING OBJECTIVE
>
> Describe the compliance security profile, how to establish a platform security baseline, and the difference between the audit system table and diagnostic log delivery.

01 Why: what goes wrong without them

Why a compliance baseline?

Every workspace starts with sensible defaults, but regulated data needs more, and it needs the same controls everywhere. Without a baseline, each team configures its own workspace and the weakest one sets your real security level.

RISK	PROTECTION
Each team configures its own workspace; one leaves public access open	**One baseline.** The same controls on every workspace, deployed from code.
Settings are changed by hand and silently drift	**Drift checks.** Scheduled scans compare each workspace to the baseline.
Unpatched cluster images run for months	**Compliance security profile.** Hardened images and automatic monthly updates.
An auditor asks you to prove regulated data is protected	**Documented controls.** A baseline gives you a list to evidence, control by control.

Why audit logs?

Permissions say who *could* act. Audit logs record who *did*: every sign-in, grant, query and secret read. They are the evidence for auditors and the first thing you need in an incident.

RISK	PROTECTION
Data leaks and nobody can say who accessed it	**Access events.** Every table read, grant and download is recorded with identity and IP.
An admin grants themselves access and removes it afterwards	**Permission change events.** The grant and the revoke are both logged permanently.
Compromised credentials are used from an unknown location	**Sign-in events + alerts.** Failed and unusual sign-ins raise alerts in real time.
Regulation requires years of evidence	**Retention you control.** Logs delivered to your own storage or Log Analytics.

THE CYCLE **Define** the baseline → **Enforce** it on every workspace → **Log** every action → **Review** and alert

02 The compliance security profile

The compliance security profile (CSP) is a workspace setting for processing regulated data such as health records (HIPAA) or card data (PCI-DSS). It changes the **compute plane**: cluster VMs run a hardened image with security monitoring agents and are patched on a fixed schedule. It requires the Premium plan and the Enhanced Security and Compliance add-on.

CAPABILITY	STANDARD WORKSPACE	WITH COMPLIANCE SECURITY PROFILE
Compute image	Standard Databricks Runtime image	+ CIS-hardened image with security agents installed
Malware and file integrity monitoring	Off, unless enhanced security monitoring is enabled on its own	+ On: antivirus, behaviour-based malware detection and file integrity monitoring
Vulnerability scanning	Not performed on cluster hosts	+ Hosts are scanned regularly for vulnerabilities
Patching	Clusters pick up fixes when you restart them	+ Automatic cluster update restarts compute in a monthly maintenance window
Monitoring events	None	+ Written to audit logs (e.g. service names capsule8-alerts-dataplane, clamAVScanService-dataplane)
Available features	All GA and preview features	! Only features and runtimes supported for the profile
Can be turned off	Not applicable	! No. Permanent for the workspace
Cost	Included in the plan	! Enhanced Security and Compliance add-on charge

WHERE TO TURN IT ON

> **Account console:** enable for all new workspaces in the account, so no workspace is created without it.

> **Workspace:** enable on an existing workspace in its security settings, or at creation in ARM, Bicep or Terraform.

> **Standards:** choose the ones you process (e.g. HIPAA, PCI-DSS). This records intent; the controls applied are the same.

BEFORE YOU ENABLE

It **cannot be turned off** for that workspace.

Running compute must be restarted to pick up the hardened image.

Monthly maintenance restarts long-running clusters and streaming jobs. Design them to recover.

Some preview features and older runtimes are unavailable. Check the supported list.

WHAT IT DOES NOT DO

> Make you compliant. You remain responsible for access control, network design, data handling and your own evidence.

> Replace the rest of the baseline. It hardens compute; identity, network and data controls are still yours to configure.

03 Establishing a platform security baseline

A baseline is a written list of controls applied to every workspace, deployed as code so it can't drift. Controls are configured in four places: **Entra ID**, **Azure**, the **Databricks account** and each **workspace**. Tick each control to assess a workspace.

Identity

0/4

- [ ] Single sign-on with Entra ID; Conditional Access requires MFA for Azure Databricks
  `ENTRA ID`
- [ ] Identities synced to the account; no local workspace users
  `DATABRICKS ACCOUNT`
- [ ] Few admins; PIM for Azure roles on the workspace
  `ENTRA ID`
- [ ] Personal access tokens disabled or limited to a short lifetime
  `WORKSPACE`

Network

0/4

- [ ] VNet injection with secure cluster connectivity (no public IPs)
  `AZURE`
- [ ] Private Link for front-end and back-end, or IP access lists
  `AZURE`
- [ ] Outbound traffic routed through a firewall
  `AZURE`
- [ ] Storage and Key Vault firewalls with private endpoints
  `AZURE`

Data

0/4

- [ ] Unity Catalog on every workspace; no business data in DBFS root
  `DATABRICKS ACCOUNT`
- [ ] Storage reached through the Access Connector managed identity; shared key access disabled
  `AZURE`
- [ ] Grants to groups; row filters and column masks on sensitive columns
  `UNITY CATALOG`
- [ ] Customer-managed keys where regulation requires key control
  `AZURE`

Compute

0/4

- [ ] Cluster policies for all users; unrestricted cluster creation removed
  `WORKSPACE`
- [ ] Only Unity Catalog access modes (standard or dedicated)
  `WORKSPACE`
- [ ] Auto-termination on all-purpose compute
  `WORKSPACE`
- [ ] Compliance security profile on workspaces with regulated data
  `DATABRICKS ACCOUNT`

Workspace settings

0/3

- [ ] Results download and notebook export off where not needed
  WORKSPACE
- [ ] Verbose audit logs on
  WORKSPACE
- [ ] Secrets in Key Vault-backed scopes only
  WORKSPACE

Monitoring

0/4

- [ ] Diagnostic settings deliver logs to Log Analytics or Sentinel
  AZURE
- [ ] Security team has SELECT on system.access
  UNITY CATALOG
- [ ] Alerts on admin changes, grants and failed sign-ins
  AZURE
- [ ] Security Analysis Tool runs on a schedule
  WORKSPACE

1 · DEFINE

Write the baseline as a short standard, with an owner and an exception process.

2 · DEPLOY AS CODE

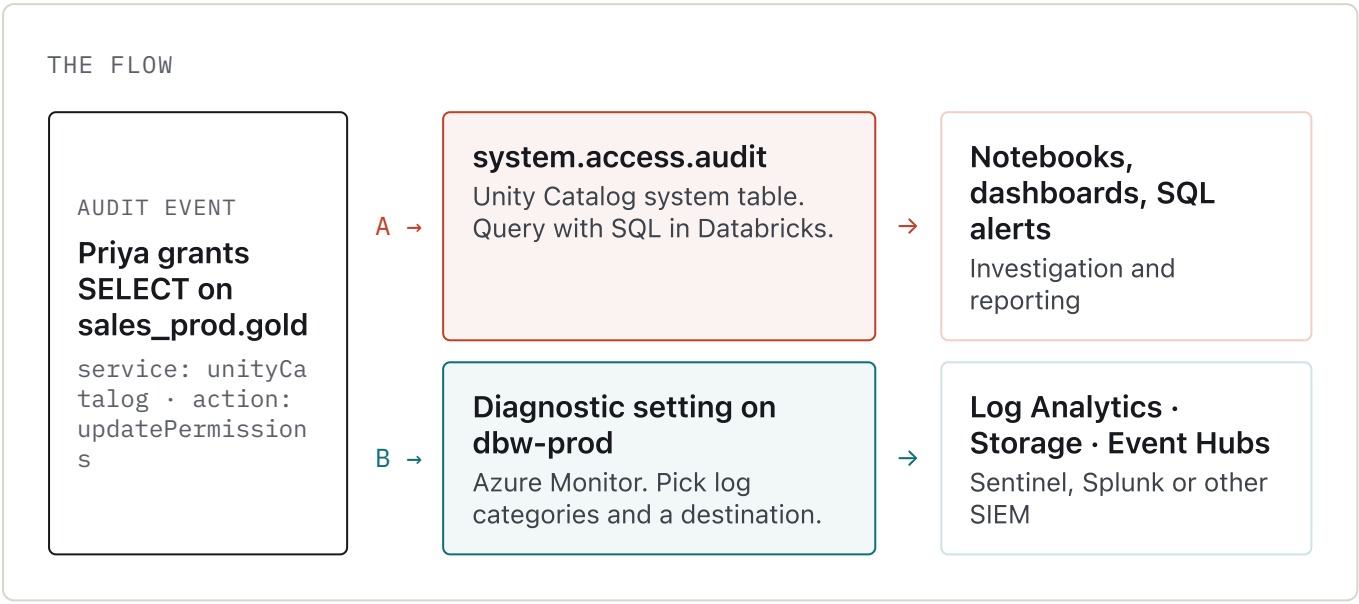
Terraform or Bicep creates every workspace with the same settings. Azure Policy blocks non-compliant resources.

3 · CHECK FOR DRIFT

Run the Databricks Security Analysis Tool (SAT) on a schedule. It scores workspaces against best-practice checks.

04 Audit logging: two ways to get the same events

Databricks records the same audit events either way. You choose how to receive them: query them inside Databricks from a **system table**, or have Azure deliver them to your own tools through **diagnostic settings**. Most organisations use both.



	A · AUDIT SYSTEM TABLE	B · DIAGNOSTIC LOG DELIVERY
Configured in	Databricks. Account admin grants access to the system.access schema.	Azure portal, ARM or Terraform: a diagnostic setting on each workspace resource.
Scope	All workspaces in the account, plus account-level events (e.g. account console changes).	One workspace per setting. Account-level events are not included.
Requires	Unity Catalog-enabled workspace	Premium plan
Latency	Typically within an hour; not for real-time alerting	Minutes; suitable for alerting
Retention	365 days, managed by Databricks	You decide: Log Analytics retention and archive, or storage lifecycle rules
Query with	SQL in notebooks, dashboards and SQL alerts	KQL in Log Analytics; any tool for storage or Event Hubs
Who controls it	Data platform team, inside Databricks	Security team, outside Databricks. Admins in Databricks cannot tamper with it
Cost	No extra charge to store; compute to query	Log Analytics ingestion and retention charges
Best for	Investigation, usage analysis, joining with lineage and billing tables	SIEM integration, real-time alerts, long-term regulatory retention

KEY COLUMNS · SYSTEM.ACCESS.AUDIT	
event_time / event_date	When it happened (UTC)
workspace_id	Which workspace; 0 for account-level events
user_identity.email	Who: user or service principal
service_name · action_name	What: e.g. unityCatalog · updatePermissions
request_params	Details: object names, scope, changes
source_ip_address	From where
response.status_code	Result: 200 success, 403 denied

Turn on verbose audit logs

A workspace setting that adds the text of every notebook command and SQL query to the audit events. Without it you can see that a notebook ran, but not what it did. It applies to both delivery methods.

Recommended: use both

Send diagnostic logs from every workspace to Log Analytics or Sentinel for real-time alerting and long retention the security team controls. Give data platform admins SELECT on `system.access` for investigation, usage reports and account-level events.

05 Which log answers this question?

Five audit questions, each answered with both queries.

Who changed permissions?

Every GRANT and REVOKE in Unity Catalog is logged as updatePermissions, with the object and the changes requested.

A · SQL ON SYSTEM.ACCESS.AUDIT

```
SELECT event_time, user_identity.email,
       request_params.securable_full_name,
       request_params.changes
FROM system.access.audit
WHERE service_name = 'unityCatalog'
  AND action_name = 'updatePermissions'
  AND event_date >= current_date() - 30
ORDER BY event_time DESC;
```

B · KQL IN LOG ANALYTICS

```
DatabricksUnityCatalog
| where TimeGenerated > ago(30d)
| where ActionName == "updatePermissions"
| project TimeGenerated, Identity,
          RequestParams, Response
| order by TimeGenerated desc
```

Best source: Either. Use B to alert the security team in real time; use A to review changes across all workspaces at once.

Who accessed a sensitive table?

Audit events show who requested a table and its credentials. For which queries actually read it, join with the lineage system table.

A · SQL ON SYSTEM.ACCESS.AUDIT

```
SELECT event_time, user_identity.email,
       action_name, source_ip_address
FROM system.access.audit
WHERE service_name = 'unityCatalog'
  AND action_name IN ('getTable',
      'generateTemporaryTableCredential')
  AND request_params.full_name_arg =
      'sales_prod.gold.customers'
  AND event_date >= current_date() - 7;
```

B · KQL IN LOG ANALYTICS

```
DatabricksUnityCatalog
| where TimeGenerated > ago(7d)
| where ActionName in ("getTable",
    "generateTemporaryTableCredential")
| where RequestParams has
    "sales_prod.gold.customers"
| project TimeGenerated, Identity,
          ActionName, SourceIPAddress
```

Best source: A. It sits next to system.access.table_lineage, which records the tables each query read and wrote.

Failed sign-ins

Sign-in attempts to a workspace are logged by the accounts service. A spike of failures from one IP suggests a guessed or stolen credential.

A · SQL ON SYSTEM.ACCESS.AUDIT

```
SELECT event_time, user_identity.email,
       source_ip_address, action_name,
       response.status_code
FROM system.access.audit
WHERE service_name = 'accounts'
  AND action_name LIKE '%Login'
  AND response.status_code <> 200
  AND event_date >= current_date() - 1;
```

B · KQL IN LOG ANALYTICS

```
DatabricksAccounts
| where TimeGenerated > ago(1d)
| where ActionName endswith "Login"
| extend status = toint(
    parse_json(Response).statusCode)
| where status != 200
| summarize failures = count()
    by SourceIPAddress, bin(TimeGenerated, 15m)
```

Best source: B, with an alert rule. Also check Entra ID sign-in logs, where Conditional Access blocks are recorded.

Who read a secret?

Each call to dbutils.secrets.get is logged as getSecret with the scope and key name. The value is never logged.

A · SQL ON SYSTEM.ACCESS.AUDIT

```
SELECT event_time, user_identity.email,
       request_params.scope,
       request_params.key
FROM system.access.audit
WHERE service_name = 'secrets'
  AND action_name = 'getSecret'
  AND request_params.scope = 'kv-erp-prod';
```

B · KQL IN LOG ANALYTICS

```
DatabricksSecrets
| where ActionName == "getSecret"
| where RequestParams has "kv-erp-prod"
| project TimeGenerated, Identity,
          RequestParams
```

Best source: Either. For Key Vault-backed scopes, Key Vault's own diagnostic logs record the read as well.

Compliance profile alerts

On workspaces with the compliance security profile, the monitoring agents on cluster hosts report detections as audit events.

A · SQL ON SYSTEM.ACCESS.AUDIT

```
SELECT event_time, workspace_id,
       service_name, action_name,
       request_params
FROM system.access.audit
WHERE service_name IN (
    'capsule8-alerts-dataplane',
    'clamAVScanService-dataplane')
  AND event_date >= current_date() - 7;
```

B · KQL IN LOG ANALYTICS

```
// Enable the matching log categories
// in the workspace diagnostic setting
DatabricksCapsule8Dataplane
| union DatabricksClamAVScan
| where TimeGenerated > ago(7d)
| project TimeGenerated, ActionName,
          RequestParams
```

Best source: B routed to Sentinel, so a malware detection reaches the security operations team as an incident.

Baseline first, profile where required

Every workspace gets the baseline. Add the compliance security profile to workspaces that process regulated data.

Deploy as code, check for drift

A control that was configured by hand once will not stay configured. Terraform, Azure Policy and SAT keep it in place.

Logs are only useful if someone looks

Turn on verbose logging, deliver logs to the security team, and set alerts on admin changes, grants and failed sign-ins.